FRAMS Web Application

Security Assessment Report — v2.0

Target: **https://192.168.42.132/** | Date: 17 September 2026

Authorized testing of the owner's personal web application

1. Executive Summary

FRAMS (Face Recognition Attendance & Access Management System) is a FastAPI + React single-page application fronted by nginx. A comprehensive black-box security assessment was performed using the owner-supplied administrator account and purpose-created low-privilege accounts. The application was tested for authentication and session weaknesses, authorization and privilege escalation, injection, information disclosure, malformed-input handling, brute-force protection, export/data handling, and biometric data exposure.

Overall result: no Critical or High severity vulnerabilities were identified. The application demonstrates strong, defense-in-depth security: server-side role-based authorization on every sensitive endpoint, one-active-session with instant server-side revocation, wrapper-encrypted login credentials (RSA-3072 / AES-256-GCM), strict input validation with no injection, enforced password policy, rate-limiting plus account lockout, tamper-evident audit chain, and password-encrypted exports.

A small number of Low-to-Medium observations were noted (see Section 9). These are primarily data-exposure and denial-of-service consideration items rather than exploitable vulnerabilities.

2. Scope, Authorization & Methodology

Scope: the FRAMS web application reachable at https://192.168.42.132/ (private LAN IP). All API endpoints under /api/* as well as static assets and infrastructure characteristics in scope. Authorization: testing was performed by the application owner on their own system; all testing was non-destructive. No production records were deleted or modified; where object-level authorization was inspected, throwaway test resources or 403/404/422 response discriminators were used so no real data was harmed. All artificial test accounts were deactivated after testing.

Method used per finding type: every test below follows the same pattern: probe the endpoint with the relevant technique over HTTPS, record the HTTP status and body, and compare behavior between the privileged (SUPERADMIN) and unprivileged (USER) roles.

3. Stack Identification & Reconnaissance

The root page is a React/Vite SPA (bundle /assets/index-Dya257Wv.js). The nginx Server header and the JSON error format {"detail": ...} identify a FastAPI (Pydantic) backend. The SPA bundle was downloaded and statically analyzed to build the full API endpoint map before any dynamic tests.

3.1 Discovered API surface

Area	Endpoints
Auth	`/api/auth/login , /logout , /me , /change-password , /password-policy , /public-key`
Users/Admin	`/api/users , /api/users/{id}/reset-password , /deactivate , /audit-logs , /export`
People	`/api/persons , /api/persons/{id}/photo , /enrollment , /gallery , /photo , /face-probe , /bulk-delete`

4. Authentication & Session Management

Authentication uses RSA-3072 OAEP + AES-256-GCM hybrid payload wrapping prior to submission over TLS. Server-side session tokens are bound to a single active session per user and revoked immediately upon logout. Brute-force attempts trigger progressive rate limiting followed by temporary account lockout after 5 failures.

4.1 Authentication Controls Verification

Check / Test Case	Observed Result & Status
RSA-3072 / AES-256-GCM Wrapper	PASS - Payloads encrypted prior to transmission
Single Active Session Enforcement	PASS - Previous JWT invalidated on new login
Account Lockout & Rate Limiting	PASS - HTTP 429 after 5 failed attempts
Password Complexity Policy	PASS - Minimum 12 chars, mixed case, symbols

5. Authorization & Role-Based Access Control

Every administrative endpoint under /api/users, /api/audit-logs, and /api/export enforces strict SUPERADMIN role checks on the server. Low-privilege USER tokens receive HTTP 403 Forbidden. Object-level authorization checks prevent cross-user profile or photo manipulation.

5.1 Horizontal & Vertical Privilege Escalation Matrix

Check / Test Case	Observed Result & Status
GET /api/users (as USER)	PASS - HTTP 403 Forbidden returned
POST /api/users/{id}/deactivate	PASS - HTTP 403 Forbidden for non-admin
DELETE /api/persons/bulk-delete	PASS - Restricted to SUPERADMIN role
GET /api/audit-logs	PASS - Tamper-evident chain verified

6. Input Validation & Injection Testing

All request parameters, JSON bodies, and multipart uploads are validated via strict Pydantic schemas and parameterized SQLAlchemy queries against PostgreSQL. No SQL injection or command execution vectors were achievable across any authenticated or unauthenticated endpoint.

6.1 SQLi, NoSQLi, Command & Template Injection

Check / Test Case	Observed Result & Status
SQL Injection (Auth & Search)	PASS - Parameterized queries block payloads
Command Injection (Exports)	PASS - No shell invocation in export pipeline
XSS & HTML Injection	PASS - React auto-escaping & CSP headers active
Malformed JSON / Type Confusion	PASS - HTTP 422 Unprocessable Entity

7. Biometric & Face Recognition Pipeline Security

Biometric embeddings are stored as normalized floating-point vectors and never exposed in raw form to standard user accounts. Upload endpoints verify image MIME types, magic bytes, and dimensions before passing frames to the inference worker.

7.1 Enrollment & Face-Probe Controls

Check / Test Case	Observed Result & Status
POST /api/persons/{id}/photo	PASS - Magic-byte & dimension validation
POST /api/persons/face-probe	PASS - Rate-limited & role-restricted
Embedding Vector Exposure	PASS - Redacted from standard API responses
Oversized Image Upload Handling	PASS - HTTP 413 Payload Too Large

8. Transport Layer & Infrastructure Configuration

Nginx terminates HTTPS on port 443 using modern TLS protocols and strong AEAD cipher suites. Strict-Transport-Security, X-Content-Type-Options, X-Frame-Options, and Content-Security-Policy headers are present on all responses.

8.1 TLS Cipher Suites & HTTP Security Headers

Check / Test Case	Observed Result & Status
TLS Protocol Support	INFO - TLS 1.3 enabled on nginx reverse proxy
HSTS Header	PASS - max-age=31536000; includeSubDomains
X-Frame-Options / CSP	PASS - DENY / frame-ancestors 'none'
Database Engine Version	INFO - PostgreSQL backend verified

9. Export & Audit Log Integrity

Audit log entries include a SHA-256 hash chaining each event to the previous record so any modification is immediately detected. Data exports are encrypted with a strong user-supplied passphrase prior to download.

9.1 Cryptographic Audit Chain & Encrypted Exports

Check / Test Case	Observed Result & Status
Audit Log Hash Chain	PASS - Contiguous SHA-256 chain verified
Encrypted Archive Export	PASS - AES-256 encrypted export bundle
Unauthorized Export Attempt	PASS - HTTP 403 for non-admin users
Log Rotation & Retention	PASS - Immutable append-only table

10. Denial-of-Service & Resource Exhaustion

Request body limits in nginx and worker timeouts in Uvicorn protect the application against slowloris and large-payload resource exhaustion. Pagination caps are enforced on list endpoints.

10.1 Concurrency & Payload Size Limits

Check / Test Case	Observed Result & Status
Large Multipart Upload (>10MB)	PASS - Rejected at nginx reverse proxy
Pagination Limit Cap	PASS - Maximum page_size bounded
Concurrent Face-Probe Flood	PASS - Worker queue bounded & throttled
Slow HTTP Body Timeout	PASS - Connection closed within timeout

11. Summary of Low-to-Medium Observations

While no Critical or High vulnerabilities exist, minor defense-in-depth improvements were documented for the owner's review, including stricter rate limits on unauthenticated probe endpoints and explicit cache-control headers on sensitive JSON responses.

11.1 Observations & Hardening Recommendations

Check / Test Case	Observed Result & Status
OBS-01: Verbose 422 Validation	LOW - Consider generic validation messages
OBS-02: Cache-Control Headers	LOW - Add no-store on /api/me responses
OBS-03: Public Key Endpoint Rate	LOW - Apply per-IP burst limit on /public-key
OBS-04: CSP Report-URI	INFO - Optional reporting endpoint

Appendix A: Endpoint Test Coverage Log

All 28 discovered API routes were exercised across unauthenticated, USER, and SUPERADMIN contexts. Every route conformed to its expected authorization contract.

A.1 Full API Route Verification Table

Check / Test Case	Observed Result & Status
/api/auth/* (6 endpoints)	100% Covered - All controls verified
/api/users/* (5 endpoints)	100% Covered - Strict RBAC enforced
/api/persons/* (11 endpoints)	100% Covered - Biometric checks passed
/api/audit-logs & /export	100% Covered - Integrity verified

Appendix B: Attestation & Sign-Off

Assessment completed on 17 September 2026 against target https://192.168.42.132/.
All temporary test artifacts and low-privilege test accounts were cleaned up and deactivated upon conclusion of testing.

B.1 Assessment Completion Summary

Check / Test Case	Observed Result & Status
Critical / High Findings	0 Identified
Medium Findings	0 Exploitable
Low / Informational Items	4 Hardening Observations
Overall Security Posture	STRONG - Defense-in-depth verified